

Task 3 Incident Response Policy

By **Stephen Reilly** | *Security Policy Analysis Series*

Objective

Create a comprehensive Incident Response Policy that defines how the organization handles security incidents.

NIST IR Lifecycle

Preparation -> Detection & Analysis -> Containment/Eradication/Recovery -> Post-Incident

Scenario

Company: GlobalTech Manufacturing

Size: 2,000 employees across 5 countries

Industry: Manufacturing with IoT/OT systems

Compliance: ISO 27001, GDPR, Industry-specific regulations

Requirements

Create an Incident Response Policy covering:

1. Incident Classification

Define severity levels:

Severity	Description	Response Time	Examples
Critical	[Define]	[Time]	[Examples]
High	[Define]	[Time]	[Examples]
Medium	[Define]	[Time]	[Examples]
Low	[Define]	[Time]	[Examples]

2. Incident Response Team

Define roles and responsibilities:

- Incident Response Manager
- Security Analysts
- IT Support
- Legal Counsel
- Communications/PR
- Executive Sponsor

3. Detection and Reporting

- How incidents are detected

- How to report an incident
- What information to collect
- Initial assessment procedures

4. Response Procedures

Containment: Short-term, evidence preservation, long-term

Eradication: Root cause, threat removal, validation

Recovery: System restoration, testing, monitoring

5. Communication Plan

Stakeholder	When to Notify	Method
Executive Management	[When]	[Method]
Legal	[When]	[Method]
Regulators	[When]	[Method]
Affected Users	[When]	[Method]

6. Evidence Handling

- Chain of custody procedures
- Evidence preservation
- Documentation requirements

7. Post-Incident Activities

- Lessons learned process
- Report requirements

Deliverables

1. Complete Incident Response Policy
2. Incident Classification Matrix
3. Communication Plan
4. Incident Report Template

Incident Response Policy

GlobalTech Manufacturing

Version: 1.0

Effective Date: June 22, 2026

Review Date: June 22, 2027 (Annual)

Owner: Chief Information Security Officer (CISO)

Approver: Executive Board / Audit Committee

1. Purpose and Scope

The purpose of this policy is to establish a standardized framework for detecting, responding to, and recovering from security incidents at GlobalTech Manufacturing. This policy ensures compliance with ISO 27001, GDPR, and industry-specific regulations while protecting our intellectual property, customer data, and critical Operational Technology (OT) infrastructure.

Scope: This policy applies to all employees, contractors, third-party vendors, and systems (IT and OT/IoT) owned or operated by GlobalTech across its five global locations.

2. Reference Frameworks

This policy aligns with:

- **NIST SP 800-61 Rev. 2:** Computer Security Incident Handling Guide (Lifecycle: Preparation, Detection & Analysis, Containment/Eradication/Recovery, Post-Incident).
- **ISO/IEC 27001:** Information Security Management Systems.
- **GDPR:** General Data Protection Regulation (for personal data breach notification timelines).
- **NIST CSF:** Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover).

3. Incident Classification Matrix

Incidents are classified based on potential impact on confidentiality, integrity, availability, and operational continuity (specifically regarding production lines and safety systems).

Severity Level	Definition	Response Time (SLA)	Examples
Critical (Sev-1)	Immediate threat to human safety, total loss of production capability, massive data exfiltration (>10k records), or active ransomware on core infrastructure.	< 15 Minutes	• Ransomware encrypting PLC/SCADA systems • Active DDoS shutting down global ERP • Confirmed theft of trade secrets/IP • Physical safety system compromise
High (Sev-2)	Significant degradation of services, potential data breach (<10k records), or localized production stoppage requiring manual intervention.	< 1 Hour	• Phishing campaign with credential harvest attempt • Malware infection on non-production servers • Unauthorized access to HR/Finance databases • IoT device hijacking affecting local network • Single endpoint virus infection (contained)
Medium (Sev-3)	Minor service disruption, isolated policy violation, or low-risk malware containment required. No immediate business impact.	< 4 Hours	• Failed login attempts indicating brute force • Misconfiguration exposing non-sensitive data • Spam flood affecting email throughput

Severity Level	Definition	Response Time (SLA)	Examples
Low (Sev-4)	Informational events, policy anomalies, or successful attacks with zero impact. Requires logging but no immediate action.	< 24 Hours (or next business day)	• Policy violation (e.g., unauthorized software install) • Port scan detected and blocked by firewall • False positive alerts • Minor configuration drift

4. Incident Response Team (IRT) Structure

The IRT operates under a unified command structure. Roles are defined below with primary responsibilities.

4.1 Incident Response Manager (IRM)

- **Role:** Overall lead; coordinates all response activities.
- **Responsibilities:** Activates the IRT, prioritizes actions, manages communication flow, and serves as the single point of contact for senior leadership.

4.2 Security Analysts

- **Role:** Technical execution.
- **Responsibilities:** Perform detection analysis, forensic imaging, malware reverse engineering, and implement technical containment. Specialized analysts for OT/IoT systems must be included in major incidents.

4.3 IT Support & Operations

- **Role:** Infrastructure restoration.
- **Responsibilities:** Assist with system isolation, patch deployment, backup restoration, and validation of system integrity post-eradication.

4.4 Legal Counsel

- **Role:** Compliance and liability management.
- **Responsibilities:** Advise on GDPR breach notification timelines (72 hours), regulatory reporting requirements, contract obligations with vendors, and privilege protection for investigation.

4.5 Communications / PR

- **Role:** External and internal messaging.
- **Responsibilities:** Draft public statements, manage media inquiries, coordinate employee notifications, and ensure messaging does not compromise legal proceedings.

4.6 Executive Sponsor

- **Role:** Strategic decision-maker.
- **Responsibilities:** Approves budget for emergency resources, authorizes business continuity plan activation, and makes "go/no-go" decisions on production shutdowns.

5. Detection and Reporting

5.1 Detection Mechanisms

Incorporating automated and manual detection methods:

- **Automated:** SIEM alerts, EDR telemetry, IDS/IPS logs, and OT-specific anomaly detection sensors.
- **Manual:** Employee reporting via phone/email, vendor notifications, law enforcement alerts.

5.2 Reporting Procedures

- **Internal Reporting:** Any employee suspecting an incident must report immediately via the dedicated **Security Hotline** (+1-800-GLOBAL-SEC or incident@globaltech-mfg.com).
- **Escalation:** All reports go to the SOC (Security Operations Center) for triage. If SOC is unavailable, reports go directly to the IRM.

5.3 Initial Assessment

Upon receipt of a report, the first responder must collect:

1. **What:** Description of the observed behavior.
2. **When:** Timestamp of observation and estimated start time.
3. **Where:** Affected system(s), location, and network segment (IT vs. OT).
4. **Who:** User account involved (if known) and reporter identity.
5. **Impact:** Current status (active, contained, recurring).

6. Response Procedures

Aligned with the NIST Lifecycle phases.

6.1 Containment

- **Short-Term:** Immediate isolation of affected systems (air-gapping OT networks if safe to do so) to prevent spread. *Note: In OT environments, sudden shutdowns may cause physical damage; consult OT leads before disconnecting.*
- **Evidence Preservation:** Capture volatile memory (RAM), disk images, and network traffic logs before any alteration.
- **Long-Term:** Apply temporary workarounds, change credentials, and block malicious IPs/domains while maintaining operational continuity where possible.

6.2 Eradication

- **Root Cause Analysis:** Identify how the attacker gained entry (e.g., phishing, unpatched vulnerability, compromised IoT device).
- **Threat Removal:** Remove malware, close backdoors, reset compromised accounts, and patch vulnerabilities.
- **Validation:** Verify that no artifacts remain before declaring the system clean.

6.3 Recovery

- **Restoration:** Restore systems from clean backups (verified pre-infection baseline).

- **Testing:** Conduct functional testing (especially for manufacturing processes) to ensure safety and accuracy.
- **Monitoring:** Place recovered systems under heightened monitoring for 48–72 hours to detect reinfection.

7. Communication Plan

Stakeholder	When to Notify	Method	Owner
Executive Management	Immediately upon Sev-1 or Sev-2 classification.	Secure Phone Call / Encrypted Email	IRM
Legal Counsel	Upon confirmation of potential data breach or regulatory impact.	Secure Channel / In-Person	IRM
Regulators (e.g., GDPR)	Within 72 hours of becoming aware of a personal data breach.	Formal Regulatory Portal / Registered Mail	Legal Counsel
Affected Users	After consultation with Legal and PR; usually after containment.	Official Company Email / Letter	Comms/PR
Law Enforcement	If criminal activity (theft, sabotage) is confirmed.	Direct Liaison	Legal Counsel

8. Evidence Handling

To ensure admissibility in legal proceedings:

- **Chain of Custody:** A strict log must be maintained for every piece of evidence, documenting who collected it, when, where, and who held it subsequently.
- **Preservation:** Evidence must be stored in a secure, access-controlled environment (digital and physical). Hash values (SHA-256) must be calculated immediately upon collection.
- **Documentation:** All actions taken during the incident must be timestamped and logged in the central Incident Log.

9. Post-Incident Activities

- **Lessons Learned:** A formal "Post-Mortem" meeting must be held within 14 days of incident closure involving all key stakeholders.
- **Report Requirements:** A final report must include:
 - Timeline of events.
 - Root cause and attack vector.
 - Effectiveness of the response.
 - Recommendations for process or technology improvements.
- **Policy Update:** The IR Policy and procedures will be updated based on findings to prevent recurrence.

10. Documentation Standards & Control

- **Readability:** This document uses clear, concise language accessible to non-technical staff where possible. Technical terms are defined in the Appendix.
- **Version Control:** All changes to this policy require version updates (e.g., v1.1).
- **Approval:** This policy requires annual review and sign-off by the CISO and Executive Sponsor.
- **Contact for Questions:** For clarification, contact the CISO Office at ciso-office@globaltech-mfg.com.

Attachments (Deliverables Included)

1. **Incident Classification Matrix** (See Section 3)
2. **Communication Plan** (See Section 7)
3. **Incident Report Template** (See below)

Appendix: Incident Report Template

(To be filled out by the First Responder)

- **Incident ID:** [Auto-Generated]
- **Date/Time Reported:** [YYYY-MM-DD HH:MM]
- **Reporter Name/Dept:** [Name]
- **Severity Level:** [Critical / High / Medium / Low]
- **Affected Systems:** [List Hostnames/IPs]
- **Description of Incident:** [Detailed narrative]
- **Immediate Actions Taken:** [Isolation, Shutdown, etc.]
- **Evidence Preserved:** [List files/logs/images captured]
- **Current Status:** [Contained / Active / Under Investigation]
- **Next Steps Required:** [Pending Analyst Action]